



University  
of Glasgow

**Tuesday 7 May 2024**  
**09:30 – 11:30 BST**  
**Duration: 2 hours**  
**Timed exam – fixed start time**

**DEGREES OF MSc, MSci, MEng, BEng, BSc, MA and MA (Social Sciences)**

**Cyber Security Fundamentals (M)**  
**COMPSCI5063**

**(RUBRIC: Answer All Questions)**

**This examination paper is an open book, online assessment and is worth a total of 80 marks.**

| Rule | Command (by $S_0$ )                                                                                   | Authorization                                            | Operation                                                                                      |
|------|-------------------------------------------------------------------------------------------------------|----------------------------------------------------------|------------------------------------------------------------------------------------------------|
| R1   | <b>transfer</b> $\left\{ \begin{smallmatrix} \alpha^* \\ \alpha \end{smallmatrix} \right\}$ to $S, X$ | ' $\alpha^*$ ' in $A[S_0, X]$                            | store $\left\{ \begin{smallmatrix} \alpha^* \\ \alpha \end{smallmatrix} \right\}$ in $A[S, X]$ |
| R2   | <b>grant</b> $\left\{ \begin{smallmatrix} \alpha^* \\ \alpha \end{smallmatrix} \right\}$ to $S, X$    | 'owner' in $A[S_0, X]$                                   | store $\left\{ \begin{smallmatrix} \alpha^* \\ \alpha \end{smallmatrix} \right\}$ in $A[S, X]$ |
| R3   | <b>delete</b> $\alpha$ from $S, X$                                                                    | 'control' in $A[S_0, S]$<br>or<br>'owner' in $A[S_0, X]$ | delete $\alpha$ from $A[S, X]$                                                                 |
| R4   | $w \leftarrow \text{read } S, X$                                                                      | 'control' in $A[S_0, S]$<br>or<br>'owner' in $A[S_0, X]$ | copy $A[S, X]$ into $w$                                                                        |
| R5   | <b>create object</b> $X$                                                                              | None                                                     | add column for $X$ to $A$ ; store 'owner' in $A[S_0, X]$                                       |
| R6   | <b>destroy object</b> $X$                                                                             | 'owner' in $A[S_0, X]$                                   | delete column for $X$ from $A$                                                                 |
| R7   | <b>create subject</b> $S$                                                                             | none                                                     | add row for $S$ to $A$ ; execute <b>create object</b> $S$ ; store 'control' in $A[S, S]$       |
| R8   | <b>destroy subject</b> $S$                                                                            | 'owner' in $A[S_0, S]$                                   | delete row for $S$ from $A$ ; execute <b>destroy object</b> $S$                                |

Figure 1: Access control system commands.

1. In a state-of-the-art research laboratory, a sophisticated Discretionary Access Control (DAC) system is utilized to manage the sensitive information and proprietary experiments being conducted. The lab's DAC system operates according to an access matrix  $A$  that defines the permissions for subjects (users or processes) to access objects (files or resources). The laboratory has recently integrated a set of advanced DAC commands based on the rules shown in the Fig. 1 to enhance the flexibility and security of access control.

Dr. Anderson, a lead scientist, is currently working on a confidential project "Project Phoenix." He needs to collaborate with Dr. Bell, who is part of a different team, on a specific experiment within the project. Dr. Anderson wants to ensure that Dr. Bell has access only to the "Experiment Data" file (write, read) and only for the duration of this particular collaboration. The access should be revoked at the end of the project.

Explain how Dr. Anderson can securely grant and later revoke access to Dr. Bell using the DAC system. Include in your answer the specific commands Dr. Anderson must use and the authorizations required for each command. Make sure to maintain the principle of least privilege throughout the process. [6]

2. Alice, a security analyst, is working from her favorite café using the café's public Wi-Fi to access her company's cloud services. Unbeknownst to her, Eve, a skilled cybercriminal, is also in the café and has set up a Man-in-the-Middle (MitM) attack by creating a rogue access point that mimics the café's Wi-Fi. Alice unknowingly connects to this rogue access point. Eve aims to intercept and potentially alter the communications between Alice and her company's cloud services.

- (a) Explain how Eve can exploit this situation to conduct a Man-in-the-Middle attack. [5]
  - (b) Discuss the role of Robust Security Network (RSN) in preventing such attacks when using Wi-Fi and why it might not be applicable in public Wi-Fi scenarios like the café. [5]
3. Many companies, such as Google, Microsoft, etc., use single sign-on (SSO) for user authentication.
- (a) Explain the advantage of using SSO comparing with traditional individual authentication. What cybersecurity aspects (choose from Confidentiality, Integrity, Availability, Authenticity, Accountability, and Non-repudiation) can SSO user authentication provide to a company's system? Please explain the reason for each aspect achieved. [7]
  - (b) Please take the Kerberos Protocol as an example to explain the five steps of the SSO authentication process. Your answer should focus on describing how the "Ticket" is constructed and how this "Ticket" is used to authenticate users. [5]
4. A company's network administrator suspects that an employee may have been involved in unauthorized access to sensitive company data and caused the theft of sensitive data. The employee in question had access to the company's internal network and was responsible for maintaining several critical systems. The administrator noticed unusual network activity originating from the employee's work computer during off-hours.
- Based on the provided case study, answer the following questions.
- (a) Identify and describe the four specific steps that a digital forensics investigator might take in this investigation. [4]
  - (b) Outline the key pieces of digital evidence you would collect and analyze to identify the perpetrator(s) and determine the extent of the data breach [4]
5. ABC Corporation, a leading technology company, is committed to enhancing the security of its systems and applications to protect sensitive data and ensure a seamless user experience. As part of its ongoing efforts, the company decides to implement a robust user authentication system that combines password-based authentication with other authentication methods. They decide that a password is used for one-time login user authentication. Please list three biometric-based authentication methods that can be used for continuous user authentication, and specify the necessary sensors for each authentication method. [6]
6. (a) How can a web server effectively address the challenge of maintaining authentication session state across a web browser's HTTPS requests during a continuous login session? Identify two mechanisms for achieving this objective and discuss two disadvantages associated with each mechanism in terms of web application vulnerabilities. [8]
- (b) Please explain why Hypertext Transfer Protocol Secure (HTTPS) is securer than HTTP? Please list at least two reasons with detailed explanation [4]
7. In a bustling urban hospital, the wireless network is crucial for accessing patient records, communicating between departments, and ensuring that medical devices function effectively. However, the network faced a significant threat when an advanced persistent threat

(APT) group targeted the hospital's wireless infrastructure, exploiting vulnerabilities to gain unauthorized access. This breach potentially compromised patient confidentiality, disrupted medical services, and put lives at risk.

- (a) Please evaluate the implications of the security breach on the hospital's operations and patient privacy. [2]
  - (b) Propose a multi-layered security strategy that includes both technical and procedural controls to mitigate such threats in the future. [3]
8. RC4 is a stream cipher known for its simplicity and speed in software. It generates a pseudo-random stream of bits (keystream) which is then XORed with the plaintext to produce ciphertext.
- (a) Assume an attacker knows a fragment of the plaintext and the corresponding ciphertext. If the initial input key length is 5 bytes long and the known plaintext fragment is 3 bytes, describe a method to exploit vulnerabilities in RC4 to recover the key or keystream. [2]
  - (b) Given the initial key  $K[i] = i + 1$  for  $i = 0, 1, 2, 3, 4$ , perform the first 3 iterations of initial permutation of  $S$ . Show the state of vector  $S$  after these iterations. [3]
  - (c) Discuss the implications of the Invariance Weakness in RC4's initial permutation of state  $S$ . How does this weakness affect the overall security of the RC4 cipher? [2]
9. Cipher Block Chaining (CBC) mode is a block cipher encryption mode that enhances the security of the encryption by combining each plaintext block with the previous ciphertext block before encryption. The first plaintext block is combined with an Initialization Vector (IV). This method ensures that identical blocks of plaintext produce different ciphertext blocks, thus providing better security. In this question, we consider a simple CBC as detailed below.
- Block size: 4 bits
- Initialization Vector (IV): 1010
- A plaintext message  $P = 1101\ 0110\ 1001$ , 12 bits
- A simple encryption function for each block  $E(\text{Block}, \text{Key}) = \text{Block XOR Key}$ , with a constant  $\text{Key} = 0011$ .
- (a) Encrypt the given plaintext blocks using CBC mode with the provided IV and key and show the resulting ciphertext. [3]
  - (b) Discuss how changing the IV to 0010 would affect the ciphertext. [3]
10. RSA (Rivest-Shamir-Adleman) is one of the first public-key cryptosystems and is widely used for secure data transmission. In RSA, the encryption key is public, and the decryption key is kept private. The security of the system relies on the computational difficulty of factoring large prime numbers. Perform decryption using the RSA algorithm for  $p = 17$ ,  $q = 31$ , public key  $e = 17$ , ciphertext  $c = 394$ . [8]